

“Good security requires having a secure configuration defined and deployed for the application, frameworks, application server, web server, database server, and platform. All these settings should be defined, implemented, and maintained, as many are not shipped with secure defaults. This includes keeping all software up to date, including all code libraries used by the application.”

This one is pretty straightforward; however it encompasses a wide range of flaws. Getting your website or web application to work is important enough, however enough time needs to be spent on its security.

Nowadays it is pretty simple to set up a basic website. There is no dearth of free and commercial content management systems, blogging platforms, social platforms, forums etc. On the client side as well, we see a great many frameworks that aim to make a web site richer and more interactive with the use of technologies such as Ajax.

However, these applications themselves are often vulnerable, and susceptible to attack. Furthermore, many of these applications ship with default settings that are intended to work for the majority of people and might not be secure. A very serious oversight would be to not change the default password which ships with the system. An attacker who tries the defaults could then access your system with administrative privileges.

From time to time authors of these applications release updates that address these issues, however most people do not update as regularly. This means that often what websites are running are older vulnerable versions.

A misconfiguration of the web server that allows directory listing could expose important information about your site, and might help attackers discover flaws in your system in order to construct future attacks.

Often such tools also come with an administrative or wizard interface which is intended for one-time usage to help set up the server. Many times the default settings enable debug traces on the front end to help you debug. While all this might be convenient for you while setting up and testing the website, these can be used by hackers to construct attacks.

Security misconfigurations are an important source of vulnerabilities as they expose and prolong flaws that have been fixed and give hackers access to interfaces that were only intended for you.

3.2.8 Insecure cryptographic storage

“Many web applications do not properly protect sensitive data, such as credit cards, SSNs, and authentication credentials, with appropriate encryption or hashing. Attackers may steal or modify such weakly protected data to conduct identity theft, credit card fraud, or other crimes.”

When any kind of private data belonging to a user is stored on a web server, it is the host's responsibility to ensure that such data is not exposed to